

Draft - 72-Hour Breach Notification Runbook

Draft - 72-Hour Breach Notification Runbook

Status: skeleton only. Source: HUMAN_CONFIRMATION_NEEDED.md G13 - SDAIA requires controller notification within 72 hours of becoming aware of a breach, no materiality threshold (every breach size is notifiable - stricter than GDPR/US HHS), plus data-subject notification "without undue delay" where harm is possible. No runbook currently exists anywhere in this repo.

1. Detection

- Log/monitoring sources that could surface a breach: [ENGINEERING TO ENUMERATE - application logs, database access logs, any AI-provider-side incident notification, infrastructure alerts].
- Who is the first responder when an anomaly is flagged? [TO ASSIGN - likely the founder/on-call engineer at current team size; revisit as headcount grows].

2. Internal escalation (target: minutes, not hours)

1. First responder confirms whether the anomaly is a genuine personal-data breach (unauthorized access, disclosure, loss, or alteration of PHI) versus a false alarm.
2. If confirmed: escalate immediately to [FOUNDER/DPO - depends on 04's determination of whether Taweed needs a DPO at all].
3. Start an incident timeline document (who knew what, when) - this timeline is what proves the 72-hour clock was met.

3. Scope and impact assessment (target: hours, not days)

- What data was involved (categories, volume, which clinics/patients affected)?
- Root cause (as far as known at notification time - a full root-cause analysis can follow later; it must not delay the 72-hour notification itself).
- Severity/likely harm to affected data subjects.

4. Regulatory notification - SDAIA (within 72 hours of awareness, no threshold)

[COUNSEL TO CONFIRM exact notification channel/form - likely via dgp.sdaia.gov.sa or a designated SDAIA breach-reporting contact; do not assume a channel without checking current SDAIA guidance at the time this runbook is actually needed, since this is exactly the kind of detail that changes between drafting and use].

Who files: depends on 04-controller-processor-determination.md. If the clinic is controller and Taweed is processor, Taweed must notify the clinic fast enough for the clinic to hit its own 72-hour clock - meaning Taweed's internal target should be materially faster than 72 hours (e.g. notify the affected clinic within 24 hours) regardless of who ultimately files with SDAIA. Build the runbook to hit the faster internal target either way; don't wait for 04 to resolve before setting that internal SLA.

5. Data-subject notification ("without undue delay" where harm is possible)

- Template notification content: [COUNSEL TO DRAFT] - what happened, what data, what's being done, what the affected person should do.
- Who sends it: the clinic (patient-facing relationship) in most plausible scenarios, with Taweed providing the facts and drafting support - [COUNSEL TO CONFIRM this division doesn't itself need to be a term in the DPA, see 05-dpa-template.md].

6. Post-incident

- Root-cause writeup and remediation plan.
- Confirm whether any contractual notification (to Anthropic, to hosting providers) is also required depending on where the breach originated.
- Update this runbook with anything learned.

Open items before this can be finalized

1. Resolve 04 - decides who files with SDAIA and who owns the internal SLA target.
2. Counsel to confirm the actual SDAIA notification channel/form current at drafting time.
3. Engineering to enumerate real detection sources (§1) - this runbook is not usable until that's filled in with the actual stack, not placeholders.